



CYBER SECURITY

BY FUTURE INTERNS

VULNERABILITY ASSESSMENT REPORT

TASK 1: VULNERABILITY ASSESSMENT FOR A LIVE WEBSITE

TARGET WEBSITE:
DEMO.TESTFIRE.NET

PREPARED BY:
MANOJ NARUGUNDA

FUTURE INTERNS
CYBER SECURITY INTERNSHIP

INTRODUCTION:-

- **THE PURPOSE OF THIS PROJECT WAS TO PERFORM A VULNERABILITY ASSESSMENT ON A LIVE WEBSITE AND IDENTIFY COMMON SECURITY WEAKNESSES.**
- **THE ASSESSMENT WAS CONDUCTED ON THE ALTORO MUTUAL DEMO BANKING APPLICATION (DEMO.TESTFIRE.NET).**
- **THE OBJECTIVE WAS TO IDENTIFY SECURITY VULNERABILITIES, CLASSIFY THEIR RISK LEVELS, AND PROVIDE RECOMMENDATIONS TO IMPROVE WEBSITE SECURITY.**
- **THIS ASSESSMENT WAS PERFORMED USING NMAP, OWASP ZAP, AND BROWSER DEVELOPER TOOLS.**

TOOLS USED

1. NMAP

USED TO IDENTIFY OPEN PORTS AND RUNNING SERVICES ON THE TARGET WEBSITE.

2. OWASP ZAP

USED TO PERFORM PASSIVE SECURITY SCANNING AND IDENTIFY COMMON WEB VULNERABILITIES.

3. BROWSER DEVELOPER TOOLS

USED TO INSPECT HTTP HEADERS, COOKIES, AND CLIENT-SIDE RESOURCES.

4. CANVA

USED TO DESIGN AND PREPARE THE FINAL REPORT.

METHODOLOGY

STEP 1:

SELECTED THE TARGET WEBSITE (DEMO.TESTFIRE.NET).

STEP 2:

PERFORMED RECONNAISSANCE USING NMAP TO IDENTIFY OPEN PORTS AND SERVICES.

STEP 3:

BROWSED THE WEBSITE THROUGH OWASP ZAP TO CAPTURE REQUESTS AND ANALYZE SECURITY ISSUES.

STEP 4:

REVIEWED ALERTS GENERATED BY OWASP ZAP.

STEP 5:

VERIFIED SECURITY HEADERS AND COOKIE SETTINGS USING BROWSER DEVELOPER TOOLS.

STEP 6:

CLASSIFIED VULNERABILITIES BASED ON RISK LEVEL AND DOCUMENTED REMEDIATION STEPS.

VULNERABILITY FINDINGS

THE FOLLOWING SECURITY ISSUES WERE IDENTIFIED DURING THE ASSESSMENT.

Vulnerability	Risk Level
Content Security Policy (CSP) Header Not Set	Medium
Missing Anti-clickjacking Header	Medium
Cookie Without Secure Flag	Medium
Cookie No HttpOnly Flag	Medium
Server Information Disclosure	Low
X-Content-Type-Options Header Missing	Low

FINDING 1

CONTENT SECURITY POLICY (CSP) HEADER NOT SET

RISK LEVEL: MEDIUM

DESCRIPTION:

THE WEBSITE DOES NOT HAVE A CONTENT SECURITY POLICY (CSP) CONFIGURED. THIS SECURITY HEADER HELPS PROTECT WEBSITES FROM CROSS-SITE SCRIPTING (XSS) ATTACKS AND MALICIOUS CONTENT INJECTION.

IMPACT:

ATTACKERS MAY INJECT MALICIOUS SCRIPTS THAT COULD AFFECT USERS AND COMPROMISE WEBSITE SECURITY.

The screenshot displays the Burp Suite application interface. At the top, there is a navigation bar with tabs for History, Search, Alerts, Output, and WebSockets. The 'Alerts' tab is active, showing a list of 19 alerts on the left sidebar. The selected alert, 'Content Security Policy (CSP) Header Not Set (8)', is highlighted. The main panel on the right provides detailed information about this alert:

- Content Security Policy (CSP) Header Not Set**
- URL:** https://demo.testfire.net/
- Risk:** Medium (indicated by a yellow icon)
- Confidence:** High
- Parameter:**
- Attack:**
- Evidence:**
- CWE ID:** 693
- WASC ID:** 15
- Source:** Passive (10038 - Content Security Policy (CSP) Header Not Set)
- Alert Reference:** 10038-1
- Input Vector:**
- Description:** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
- Other Info:**
- Solution:** Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
- Reference:**

The bottom status bar shows 'Alerts' with counts for various risk levels (0 High, 4 Medium, 11 Low, 4 Info) and the 'Main Proxy: localhost:8080'. On the right, the 'Current Status' bar shows various icons and counts (0, 3, 0, 0, 0, 0, 0, 0, 0, 0).

FINDING 2

MISSING ANTI-CLICKJACKING HEADER

RISK LEVEL: MEDIUM

DESCRIPTION:

THE WEBSITE DOES NOT INCLUDE ANTI-CLICKJACKING PROTECTION HEADERS SUCH AS X-FRAME-OPTIONS.

IMPACT:

ATTACKERS MAY TRICK USERS INTO CLICKING HIDDEN ELEMENTS ON MALICIOUS WEBSITES.

Search Alerts Output WebSockets

Missing Anti-clickjacking Header

URL: https://demo.testfire.net/

Risk: Medium

Confidence: Medium

Parameter: x-frame-options

Attack:

Evidence:

CWE ID: 1021

WASC ID: 15

Source: Passive (10020 - Anti-clickjacking Header)

Alert Reference: 10020-1

Input Vector:

Description:

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Other Info:

Solution:

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Missing Anti-clickjacking Header (6)

No HttpOnly Flag

Without Secure Flag (3)

with SameSite Attribute None

without SameSite Attribute (5)

IP Disclosure

Pages Include Mixed Content

Leaks Version Information via "Server" HTTP Response Header

Transport-Security Disabled

Transport-Security Header Not Set (Systemic)

Cache Disclosure - Unix (Systemic)

Content-Type-Options Header Missing (26)

Scoped Cookie

Web Application

Cache-Control Directives (8)

Cache Management Response Identified (3)

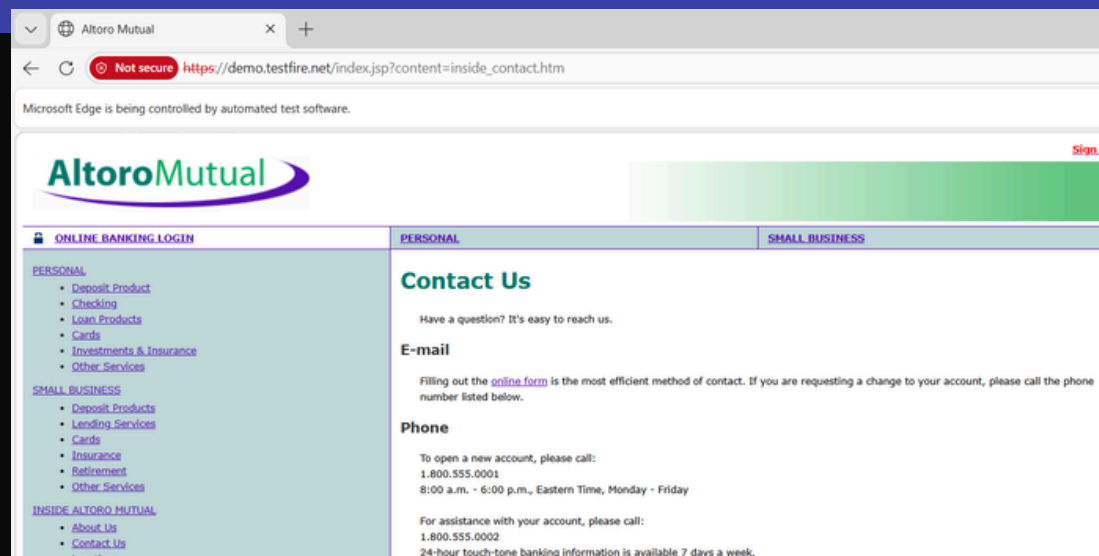
ASSESSMENT EVIDENCE

THE FOLLOWING SCREENSHOTS PROVIDE EVIDENCE OF THE VULNERABILITY ASSESSMENT PROCESS.

```
Host is up (0.28s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    open  https
8080/tcp   open  http-proxy
8443/tcp   closed https-alt

Nmap done: 1 IP address (1 host up) scanned in 31.90 seconds

C:\Users\HP>nmap -sV demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-02 11:25 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.28s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp    open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1
8080/tcp   open  http      Apache Tomcat/Coyote JSP engine 1.1
8443/tcp   closed https-alt
```



Manual Explore



This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.

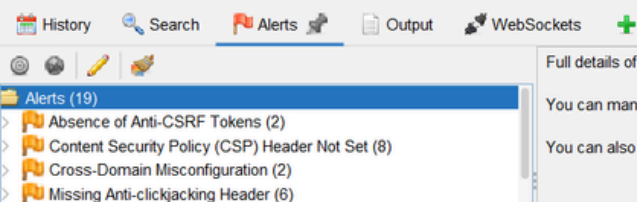
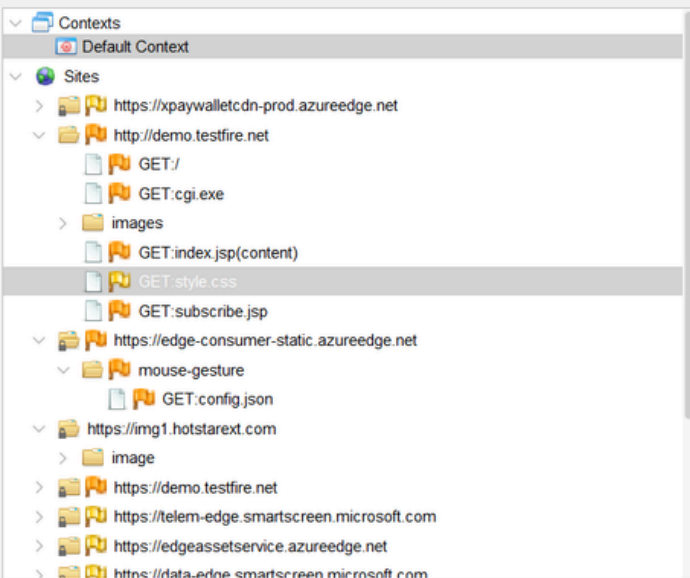
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.

URL to explore: Select...

Enable HUD: ☐

Explore your application: Launch Browser Edge ▼

You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.



Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.

You can also edit existing alerts by double clicking on them.

SECURITY RECOMMENDATIONS

1. IMPLEMENT CONTENT SECURITY POLICY (CSP).
2. CONFIGURE ANTI-CLICKJACKING HEADERS.
3. ENABLE SECURE AND HTTPONLY COOKIE FLAGS.
4. HIDE UNNECESSARY SERVER VERSION INFORMATION.
5. ADD X-CONTENT-TYPE-OPTIONS HEADER.
6. CONDUCT REGULAR VULNERABILITY ASSESSMENTS AND SECURITY REVIEWS.

CONCLUSION

A VULNERABILITY ASSESSMENT WAS SUCCESSFULLY CONDUCTED ON THE ALTORO MUTUAL DEMO BANKING APPLICATION USING NMAP, OWASP ZAP, AND BROWSER DEVELOPER TOOLS.

SEVERAL SECURITY ISSUES WERE IDENTIFIED, INCLUDING MISSING SECURITY HEADERS AND COOKIE-RELATED WEAKNESSES. MOST FINDINGS WERE CLASSIFIED AS MEDIUM RISK.

IMPLEMENTING THE RECOMMENDED SECURITY MEASURES WILL IMPROVE THE OVERALL SECURITY POSTURE OF THE APPLICATION AND REDUCE THE RISK OF COMMON WEB-BASED ATTACKS.

THIS PROJECT ENHANCED PRACTICAL KNOWLEDGE OF VULNERABILITY ASSESSMENT, SECURITY ANALYSIS, AND PROFESSIONAL REPORTING.